

Appletree Interiors ERP Master Audit & Go-Live Certification

System audited: appletree_erp_v2_1.html (16,875 lines, single-file JS + Supabase)

Method: Code-verified, file:line evidence – not interface assumption Date: 21 Jul 2026

01 · EXECUTIVE SUMMARY

A well-automated core, sitting on a weak governance layer

The Lead → Quotation → Project → Production → Dispatch chain is genuinely wired with real ID references and cascading automation — better than most first-generation internal ERPs. But the system was audited as if going live company-wide, and against that bar it has critical gaps in access control, approval integrity, and audit traceability that a 25-year ERP implementation standard would not sign off on.

4.2/10

Overall ERP maturity,
benchmarked against
SAP / Oracle / Dynamics / NetSuite / Odoo

58%

Go-live readiness — safe for
current 4-user happy-path ops,
not certifiable enterprise-wide

14/20

Critical-severity findings among
the 20 ranked issues (access
control, approvals, audit trail,
data integrity)

7

Lifecycle stages confirmed genuinely wired end-to-end with real code, not UI theatre

STRENGTH

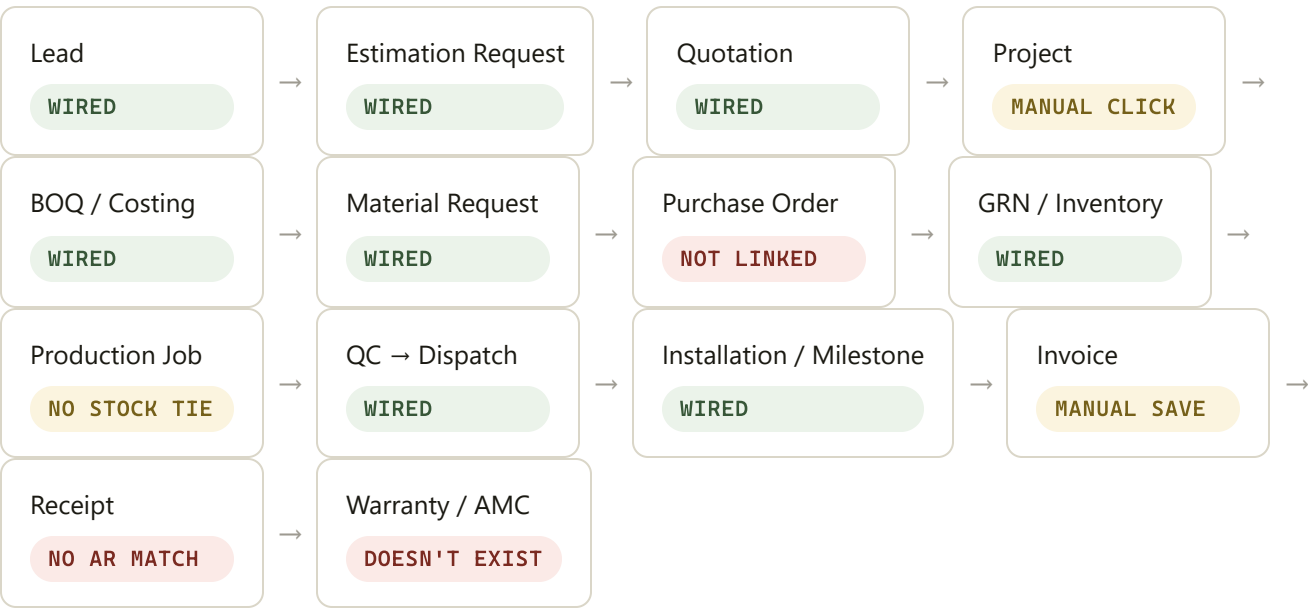
- Lead → Estimation → Quotation → Project conversion carries real IDs and re-syncs late cost changes, not a re-typed handoff (6397, 10172).
- Production is a genuine cascading state machine: last op done auto-opens QC, QC pass auto-queues dispatch, dispatch auto-fires the delivery + milestone trigger (11272-12060).
- Costing engine computes all ten expected cost components — material, wastage, hardware, labour, overhead, margin, transport/installation/finishing, GST — as real numeric fields, not placeholders (8644-8817).
- Delete-sync is correct: all 22 delete functions queue a tracked remote delete that retries on failure (16435) — the documented "records reappear after refresh" bug is genuinely fixed.
- Authentication runs on real Supabase Auth with a 30-minute inactivity timeout (16671, 9289), not a client-side password check.

CRITICAL RISK

- Role gating is enforced in only 7 of ~50 render functions; the page router itself has zero role checks (3590-3639) — any logged-in user can open Finance/HR/Payroll data via the console.
- DOA approval tiers (PO ≥ ₹5L/₹20L, quote discount ≥ 5%/10%) live only in the UI save handler — nothing revalidates on sync, so they're bypassable by direct state mutation (9053, 10309).
- The generic audit log only ever fires for Lead/Estimation entities — DOA approvals, deletions, role changes and price overrides leave no trace at all (7780-7786).
- Customer identity is fractured: Quotation/Invoice/Project customer fields are free text, customerId is hardcoded empty on save, and the "Billed" column is silently always ₹0 (7747, 7021).
- No Warranty/AMC/Service module exists — the KPI framework has literal placeholder notes admitting it (4989-4994).

Lead-to-warranty lifecycle, verified stage by stage

Every arrow below was checked against the actual conversion function, not the screen — "wired" means the target record inherits a real foreign key from the source, not just similar-looking fields.



TRANSITION	VERDICT	EVIDENCE
Lead → Estimation Request Request → Quotation	WIRED	Costed items/materials/labour copied line-by-line into the quote; re-syncs if the estimate changes after conversion 6397-6467
Quotation (Approved) → Project	MANUAL TRIGGER	Approval alone does not create a project — a human must click "Convert to Project"; once clicked, IDs and BOQ/BOM carry over correctly 9872, 10172-10239
Project → Costing Reports	WIRED	Reports pull cost breakdown from the linked quotation by projectId, since Project itself only stores totals 10048-10056
Material Request → Purchase Order	NOT LINKED	No materialRequestId field anywhere in the PO builder — procurement re-keys what to buy from scratch 8908-8994
Material Request → Warehouse Issue → Stock	WIRED	Two-phase: issue created "Pending Acceptance", stock only decrements on explicit accept 15796, 15824-15834

TRANSITION	VERDICT	EVIDENCE
PO Receipt (GRN) → Warehouse Stock	WIRED	Per-line receivedQty tracked, stock incremented, purchase ledger auto-created 9108–9144
Production Job start → Inventory reservation	NOT WIRED	No stock movement tied to job/operation start anywhere in the mfgJobs code 11494–11552
Job Ops complete → QC → Dispatch → Delivery	WIRED	Genuine cascading state machine — each stage auto-creates the next record 11272–12060
Milestone ready → Invoice	PARTIAL	Milestone pre-fills the invoice, links back on save, but nothing forces the save to happen 12476, 7748
Invoice → Receipt (AR reconciliation)	NOT LINKED	saveReceipt carries a projectId but no invoiceId — no automated matching against a specific invoice balance 7756
Stage-Gate → downstream modules	NOT ENFORCED	Gate locking only affects its own gate sequence; PO/production/dispatch have no gate check 4370–4414
QC failure → CAPA/Risk register	NOT LINKED	CAPA's "Trigger Reference" is freeform text, not a foreign key — nothing auto-creates it from a failed QC record 4558
Warranty / AMC / Service	MODULE MISSING	No module exists; KPI registry explicitly notes "No service-request/ticketing module exists yet" 4989–4994

03 · MODULE-WISE REVIEW

Strengths, gaps, and automation debt by department

Expand a module for the full breakdown. Every point below traces to a specific function.

CRM, Sales & Estimation

STRENGTHS

- Lead→Won auto-creates/dedupes the customer record via case-insensitive name match
7896–7925
- Quotation revision numbering exists (revisionNo) and is visible as "Rev N"
6455, 9863
- Estimation-to-quotation conversion is idempotent and re-syncable after late edits
6435–6449

GAPS

- Quotation/Invoice customer field is free-text-with-suggestions only; customerId is hardcoded to ' ' on save 7747, 7979
- ensureCustomerExists only fires from the Leads screen — Quotation, Invoice and Project entry points all still allow re-typing 10328
- No edit function exists for a saved Customer record — a typo can never be corrected in the UI
7983–7987
- Revision tracking keeps only the current integer — no diff or history log of what changed between revisions

Costing & BOQ Engine

STRENGTHS

- All ten expected cost components are real computed fields: material, per-material wastage %, hardware/accessories, labour (incl. named transport/install/glass lines), overhead %, profit margin %, GST 8644–8817, 9834
- PO Builder correctly picks materials from the Item Master by ID, not free text 8950–8952

GAPS

- Material/Item master is split into two disconnected arrays — DB.items (warehouse/PO) and DB.costingMaterials (BOQ engine) — with no cross-reference 3399, 3444
- No item edit function exists — rates can only be added, never corrected 7956–7960
- Rate/default-% changes never propagate: costing results and BOM row rates are frozen numbers at save time, with no re-calc trigger anywhere in the file 6410, 14730–14774
- BOQ's "+ Manual Item" lets authors bypass both material masters with free-text description/rate
10395–10414

Procurement & Inventory

STRENGTHS

- GRN is a real quantity-tracked event (receivedQty per line, partial/full receipt states), not a status flip [9108-9157](#)
- Issue and Return both run a genuine two-phase ledger — created "Pending Acceptance", stock only moves on explicit accept [15796-15839](#), [7698](#)
- Delete-sync correctness confirmed across all 22 delete functions with retry-safe queuing [16435-16441](#)

GAPS

- No link from Material Requests to Purchase Orders at all — procurement re-keys demand instead of pulling it [8908-8994](#)
- A second, parallel purchase-entry path (savePurBuilder) bypasses the acceptance workflow and writes stock directly — inconsistent with the GRN path [16306-16328](#)
- No multi-warehouse transfer function exists anywhere in the file (confirmed by grep) — no location field on warehouse items either
- QC rejection has no code path that reverses/adjusts warehouse stock
- Customers, Projects, Employees, Workers, Vendors, Items, Machines, Leads and Invoices have no delete function at all — bad master records can never be removed, only accumulate

Production & Factory / MES

STRENGTHS

- Genuine cascading automation: last operation complete auto-opens a QC record; QC pass auto-queues dispatch; dispatch auto-fires delivery + milestone trigger [11272-12060](#)

GAPS

- Job/operation creation is fully manual — no cutting list, material issue, or machine schedule is generated from the approved BOM [11494-11552](#)
- Starting or running a job never consumes/reserves inventory — the only stock exit is the separate MR→Issue flow, independent of production status
- Material and labour cost on each operation are manually typed ₹ fields, not pulled from the costed BOM [11551-11552](#)

QC, Stage-Gate, CAPA & Risk

STRENGTHS

- Stage-Gate and CAPA/Risk registers exist as real modules with computed severity and effectiveness-check enforcement (per company BOS \$9.7/\$10, built in earlier phases)
- QC pass/fail state feeds correctly into the production→dispatch cascade [11316–11339](#)

GAPS

- Stage-Gate completion doesn't block any other module — PO send, production start and dispatch have no gate check [4370–4414](#)
- CAPA's "Trigger Reference" is freeform text, not a foreign key — a failed QC record never auto-drafts a CAPA [4558](#)
- These governance modules are effectively islands: correct internally, invisible to the operational modules they're meant to govern

Finance & Accounts

STRENGTHS

- Milestone-triggered invoicing is real — dispatch and PO delivery events flip milestones to "Ready to Invoice" and pre-fill the invoice form [12464](#), [12476](#)
- GRN auto-creates a purchase ledger entry for accounts to reconcile against [9138–9144](#)

GAPS

- Receipts carry no `invoiceId` — payments are matched only at the project level, not against a specific invoice balance, so there is no real AR aging [7756](#)
- The "Billed per customer" figure is silently always ₹0 because invoices are never saved with a populated `customerId` [7021](#), [7747](#)

HR & Payroll

STRENGTHS

- Employee master edits propagate correctly — department/role changes are read live by HR sub-modules keyed on `employeeId` [12761](#), [5143](#), [5280](#), [5436](#)
- Payroll intentionally snapshots name/department at generation time — correct behaviour for historical payslips, not a bug

GAPS

- No distinct HR, Cashier or Machine Operator role exists in the permission model — these functions have no dedicated identity in the system at all (see Security)

Design, CAD & Site Measurement

STRENGTHS

- None — confirmed absent, not a weak implementation

GAPS

- No module, field, or file-attachment mechanism exists for CAD drawings, drawing numbers, or revision files anywhere in the file (grep for CAD/DWG/DXF returns zero hits)
- No dedicated Site Measurement capture screen exists — dimensions live only as free-text fields scattered across BOQ/costing forms, not as a structured per-project measurement record
- Since there is no attachment system at all (confirmed under Missing Enterprise Features), drawings and measurement sheets are necessarily emailed/WhatsApped outside the ERP with zero traceability back to the project record

Snag Management, Packing & Logistics

STRENGTHS

- "Snagging" and "Site QC" are real status values on the Installation record, so a project can at least be marked as in a snag cycle
12094, 12242, 12258

GAPS

- There is no snag list — no way to record individual open items, who they're assigned to, or when they were closed. The KPI registry itself admits this: "*No snag-list module exists in the ERP yet*" 4942–4943
- "Packing" exists only as one label in the fixed list of factory operation types (MES_OPS) — not a packing checklist, packing list, or carton/shipment record 11462
- "Logistics" exists only as a single free-text budget line ("Transport / Logistics ₹") — there is no shipment tracking, carrier record, or delivery-route module 3036, 14890

Asset Management

STRENGTHS

- None — confirmed absent

GAPS

- No asset register exists — no `DB.assets` array, no render function, no depreciation/maintenance tracking for factory machinery, vehicles, tools, or office equipment
- `DB.machines` exists but only as a scheduling resource for production jobs, not an asset register with purchase value, depreciation, or maintenance history `renderMachines, ~11395`

AI Assistant

STRENGTHS

- A real, working chat-style query interface exists (`aiAsk/aiEngine`) that reads live DB data and answers questions about projects, receivables, stock, payroll, profit, factory status, vendors, material requests, quotations, QC and delays `13235-13370`
- It is genuinely wired to live data (e.g. project lookups match against `DB.projects` by client name/code), not hardcoded text

GAPS

- This is **not** ML/LLM-based AI — it is a keyword/regex router: the user's text is pattern-matched against ~18 fixed intents (`q1.match(/profit|margin|.../)`) and dispatched to a corresponding formatter function `13293-13369`. No external AI API call exists anywhere in the file (confirmed — no API/webhook calls found)
- Anything outside the ~18 recognised intents falls through to a generic `aiFallback` response — it cannot answer novel questions or reason across modules the way a real LLM-backed assistant would

Admin, Security & Access Control

STRENGTHS

- Real Supabase Auth (not client-side password comparison) with a working 30-minute inactivity auto-logout [16671](#), [9289-9296](#)
- DOA tier logic for PO send and quotation discount is genuinely implemented, not just a UI label [8831-8835](#), [9850-9854](#)

GAPS

- Full breakdown in the [Security Assessment](#) below — role granularity, enforcement coverage, DOA bypassability and audit-trail gaps are the single biggest blocker to certification

04 · STRUCTURAL MATRICES

Roles, ownership and synchronization

User Role Matrix

Permission control is module-visibility only — there is no separate Create/Edit/Delete/Approve/Export flag anywhere in the code. Only 4 of the 8 defined roles have a real seeded user; every other job function (HR, Machine Operator, Cashier, Auditor, Store Keeper, Read-Only, etc.) has no distinct identity.

ROLE	SEEDED USER?	MODULES VISIBLE	CRUD/APPROVE GRANULARITY	RESTRICTED DATA ACTUAL
CEO	Yes	Everything	Full, unrestricted	N/A
Factory Supervisor	Yes	Overview, Projects, Operations, Inventory, Factory/MES, Master Data	None — module on/off only	No — renderPage route checks 3590
Site Supervisor	Yes	Overview, Projects, Site & Installation, Operations	None	No
Accounts	Yes	Overview, Finance, Reports, Projects	None	Partial — 5 of ~15 financial guarded (Banking, WIP, F User Mgmt)

ROLE	SEEDED USER?	MODULES VISIBLE	CRUD/APPROVE GRANULARITY	RESTRICTED DATA ACTUAL
Sales	No user seeded	Overview, CRM & Sales, Projects	None	No
Estimator	No user seeded	Overview, Estimation, Projects	None	Partial — openEstCosti 6532
Procurement	No user seeded	Overview, Inventory, Projects, Master Data	None	No
Project Manager	No user seeded	Overview, Projects, Operations, Site & Installation, Factory/MES, Reports	None	No
QC Manager	No user seeded	Overview, Projects, Operations, Factory/MES, Site & Installation	None	No
HR / Cashier / Auditor / Read-Only / Machine Operator / Store Keeper	Absent from system	—	—	These job functions do not have roles at all — they inherit from the 4 seeded accounts and what happens to be given

Data Ownership Matrix

ENTITY	OWNER (WHO CREATES)	EDITABLE BY	APPROVAL REQUIRED	LOCKED AFTER APPROVAL?
Customer	Sales / Leads (auto) or any user via free-text	Nobody — no edit function exists	No	N/A

ENTITY	OWNER (WHO CREATES)	EDITABLE BY	APPROVAL REQUIRED	LOCKED AFTER APPROVAL?
Item / Material	Any user (Item Master or Costing Materials)	Nobody — no edit function exists	No	N/A
Quotation	Sales / Estimator	Any user with page access	Yes, tiered by discount % — but client-side only 9850	No — no re-validation on status change
Purchase Order	Procurement	Any user with page access	Yes, tiered by value — client-side only 8831	No — same gap
Project	Sales/Estimator (via quotation conversion)	Any user with page access	No	No
Employee / Payroll	HR (via Accounts account)	Any user with page access to those screens	No dedicated approval step found	N/A
Role / Permission matrix	Admin (saveRolePermissions)	Anyone reaching User Management	No	No — and no log of who changed it 13974

Data Synchronization Matrix

DATA	MASTER SOURCE	SYNCED TO SUPABASE?	STATUS
~57 business tables (projects, quotations, PO, inventory, HR, CAPA, etc.)	DB[key], generic ERP_KEYS loop	Yes	GOOD — upsert + tracked delete-retry 16403–16456
kpiTargets	DB.kpiTargets	No — localStorage only	GAP — not device/team shared 3432
costingSettings (default wastage/overhead/profit %)	DB.costingSettings	No — localStorage only	GAP 3447

DATA	MASTER SOURCE	SYNCED TO SUPABASE?	STATUS
users	DB.users mirrors Supabase Auth	Deliberately excluded	CORRECT BY DESIGN 3408-3409
Customer identity on Quotation/Invoice	Free-text field, not DB.customers	Syncs the wrong value (a string, not an ID)	CRITICAL 7747

05 · SECURITY ASSESSMENT

Access control is the system's weakest layer

Everything below was reproduced against actual function calls, not inferred from the UI. All findings are client-side JavaScript observations — no Supabase RLS policy could be confirmed or denied from this file alone.

CRITICAL

1. Role gating exists in only 7 of ~50 render functions; renderPage(), the actual page router, performs zero role checks 3590-3639. A logged-in Factory or Site Supervisor can open Finance, Payroll, Purchase Reports or CEO Dashboard directly from the browser console.
2. DOA approval tiers for PO send and quotation discount live entirely in the JS save-handler; nothing re-validates status or discount value at sync time, so both gates can be bypassed by mutating DB directly and calling saveDB() 9053-9064, 10309-10321.
3. The audit log (logActivity) only ever fires for Lead/Estimation-Request actions — DOA approvals, PO/quotation status changes, deletions, role-permission edits and price overrides are all invisible to it 7780-7786.
4. Only 8 coarse module-level roles exist and only 4 have a real seeded user — HR, Machine Operator, Cashier, Auditor, Store Keeper and Read-Only have no system identity at all.

HIGH

1. Legacy unsalted-SHA-256 password code (`_hashPwd/_migratePasswords`, an old `doLogin`) is still physically present and executes at load — functionally dead today because `_supabaseInit` overwrites `window.doLogin` afterward, but it's a live landmine for any future edit or revert `9239-9277`, `16671`.
2. Password policy is a bare 6-character minimum with no complexity rule, and no 2FA/MFA exists anywhere in the file `16711`.
3. No Customer or Item edit function exists in the UI at all — bad master data can only be fixed by someone editing the Supabase table directly, entirely outside any application-level control.

MEDIUM

1. DOA-gated actions have no re-authentication step — the 30-minute session timeout is the only friction on a high-value approval.
2. No document/attachment system exists, so contracts, drawings and signed approvals are necessarily handled outside the ERP (email/WhatsApp) with zero traceability back to the record they belong to.

LOW

1. Backup relies entirely on Supabase's own database backups plus a `localStorage` mirror; the in-app export function only produces a CSV of whichever table is currently on screen, not a full-database export `8074`.

06 · MISSING ENTERPRISE FEATURES

Capabilities a mature ERP would have that this one doesn't

FEATURE	STATUS	EVIDENCE
In-app notifications	PRESENT	Real notification bell + trigger logic <code>7792</code> , <code>7814</code> , <code>9388-9408</code>
Email notifications	ABSENT	No mail-send code anywhere in the file
WhatsApp integration	ABSENT	Only a lead-source label, no send logic <code>7313</code>

FEATURE	STATUS	EVIDENCE
Document / file attachments	ABSENT	Zero matches for upload or file-input anywhere
Barcode / QR code	ABSENT	No matches in file
External API / webhooks	ABSENT	Only outbound calls are to the Supabase SDK
Offline support	PARTIAL	Service worker + localStorage cache reads offline, but writes aren't queued/reconciled 8046–8053, 16871
Multi-branch / multi-company	ABSENT	org_id is a hardcoded literal in every call — single-tenant only 16450, 16749
Digital signature capture	ABSENT	"Worker Signature" is a blank printed line on paper, not a capture widget 11976
Version / revision history	PARTIAL	Quotations track a revision number; no diff or change history is retained 6455
BI dashboards beyond KPI tiles	PARTIAL	37 KPIs defined; roughly 19 compute real data, 18 are hard-coded "not tracked yet" placeholders 4800–4998
Full-database backup / export	PARTIAL	Per-table CSV export only; no whole-DB backup tool in-app 8074
Warranty / AMC / Service module	ABSENT	Confirmed absent; KPI registry has placeholder notes for it 4989–4994
Row-level security backing RBAC	UNCONFIRMED / LIKELY ABSENT	No evidence in this file of RLS policies beyond a comment referencing pending_users row ownership 16431, 16647
Asset Management (register, depreciation, maintenance)	ABSENT	No DB.assets, no render function, no matches anywhere
Design / CAD drawing management	ABSENT	Zero matches for CAD/DWG/DXF in the entire file
Site Measurement capture	ABSENT	No dedicated module; dimensions exist only as scattered free-text fields in costing forms

FEATURE	STATUS	EVIDENCE
Snag Management (tracked list, not a status label)	ABSENT	Only a status value on Installation; KPI registry admits "No snag-list module exists in the ERP yet" 4942-4943
OCR	ABSENT	No matches in the file
AI / ML suggestions	PARTIAL – NOT REAL AI	A working chat assistant exists, but it's a ~18-intent keyword/regex router over live DB data, not an ML/LLM engine 13281-13370
Mobile app	PARTIAL – PWA SHELL ONLY	Installable PWA via manifest.json + a shell-caching service worker; no offline business data, no native app manifest.json, sw.js

06B · BENCHMARK

Measured against SAP, Oracle, Dynamics 365, NetSuite, Odoo and ERPNext

All six reference systems ship the capabilities below as standard, out-of-the-box baseline (Odoo/ERPNext vary by which modules are installed, but core RBAC, audit, API and mobile access are present even in their free/community tiers). The comparison isn't about which of the six is "best" — it's whether Appletree's ERP has crossed the baseline any of them would be certified against.

CAPABILITY	SAP S/4HANA	ORACLE ERP CLOUD	DYNAMICS 365	NETSUITE	ODOO
Field/action-level RBAC (Create/Edit/Delete/Approve as separate flags)	✓	✓	✓	✓	✓
Server-side approval enforcement	✓	✓	✓	✓	✓
Comprehensive audit trail on all critical changes	✓	✓	✓	✓	✓
Native document / drawing management	✓	✓	✓	✓	✓

CAPABILITY	SAP S/4HANA	ORACLE ERP CLOUD	DYNAMICS 365	NETSUITE	ODO
Warranty / Service ticketing	✓ (add-on)	✓	✓ (Field Service)	✓	✓ (Help)
Multi-branch / multi-company	✓	✓	✓	✓	✓
REST API / integration layer	✓	✓	✓	✓	✓
Native mobile app	✓	✓	✓	✓	✓
BOM-driven production automation	✓	✓	✓	✓	✓
Configurable costing engine (wastage/overhead/margin/tax)	✓	✓	✓	✓	✓
Cascading shop-floor state machine (ops → QC → dispatch) wired out of the box	Config-dependent	Config-dependent	Config-dependent	Config-dependent	Config-dependent

Reading the row: Appletree's ERP is *ahead* of a typical fresh install on the two rows where someone has already done the configuration work — costing and the shop-floor cascade. It is behind baseline on every governance and platform row, which is exactly why the maturity score sits at 4.2/10 rather than reading as a binary "not enterprise."

07 · TOP 20 CRITICAL ISSUES

Ranked by risk, not effort

Items 1–14 are Critical severity; 15–20 are High. Fixing 1–14 is the actual bar for "must fix before go-live" — 15–20 matter but won't sink a launch on their own.

- 1

CRITICAL

Role checks exist on only 7 of ~50 render functions, and the page router itself has none — any logged-in user can open Finance/HR/Purchase data via the browser console. 3590–3639
- 2

CRITICAL

DOA approval tiers (PO ≥₹5L/₹20L, quote discount ≥5%/10%) are enforced only in the UI save-handler, not server-side — bypassable by direct state mutation. 9053–9064, 10309–10321

-
- 3 **CRITICAL** **The audit log only fires for Lead/Estimation actions** — DOA approvals, deletions, role changes and price overrides leave no trace at all. 7780–7786
-
- 4 **CRITICAL** **Quotation/Invoice customer field is free text with customerId hardcoded empty on save** — the "Billed" column is silently always ₹0. 7747, 7021
-
- 5 **CRITICAL** **Project "Client/Site Name" has no link to the Customer master at all** — a third independent free-text entry point for the same fact. 7570–7572
-
- 6 **CRITICAL** **No Customer or Item edit function exists anywhere in the UI** — bad master data can only be corrected via direct database access. 7983–7987, 7956–7960
-
- 7 **CRITICAL** **No link from Material Requests to Purchase Orders** — procurement re-keys demand instead of pulling it from what's actually needed. 8908–8994
-
- 8 **CRITICAL** **Cost/rate changes never propagate** — BOQs, quotations and project costs are frozen snapshots with no recalculation trigger. 6410, 14730–14774
-
- 9 **CRITICAL** **No Warranty/AMC/Service module exists** — the entire post-installation customer lifecycle is untracked. 4989–4994
-
- 10 **CRITICAL** **No Snag Management module** — "Snagging" is only a status label; the KPI registry itself admits no snag-list module exists. 4942–4943
-
- 11 **CRITICAL** **Receipts carry no invoiceId** — there is no automated AR reconciliation against a specific invoice balance. 7756
-
- 12 **CRITICAL** **Production job/operation creation is fully manual** — no cutting list, material issue, or machine schedule is generated from the approved BOM. 11494–11552
-
- 13 **CRITICAL** **Starting or running a production job never reserves or consumes inventory** — the only stock exit is the separate, disconnected MR→Issue flow.
-
- 14 **CRITICAL** **Only 8 coarse module-level roles exist and only 4 have a real seeded user** — HR, Machine Operator, Cashier, Auditor, Store Keeper and Read-Only have no system identity at all.
-

-
- 15 **HIGH** **Two parallel, inconsistent purchase-entry code paths exist** (poReceiveGoods acceptance workflow vs savePurBuilder direct-add) — risk of stock/ledger divergence. 9108, 16306–16328
-
- 16 **HIGH** **No multi-warehouse transfer function exists anywhere in the file** — no location field on stock items either.
-
- 17 **HIGH** **Legacy unsalted-SHA-256 password-hashing code is still physically present and load-executes**, even though superseded by Supabase Auth. 9239–9277
-
- 18 **HIGH** **Password policy is a bare 6-character minimum with no complexity rule, and no 2FA/MFA exists anywhere.** 16711
-
- 19 **HIGH** **No Design/CAD or Site Measurement module exists** — drawings and measurements are handled entirely outside the ERP with zero traceability back to a project record.
-
- 20 **HIGH** **kpiTargets and costingSettings never sync to Supabase** — localStorage-only, not shared across devices or users. 3432, 3447
-

08 · TOP 20 RECOMMENDED IMPROVEMENTS

What to build, in order

-
- 1 Move DOA approval validation server-side (Postgres function or RLS policy) so a PO/quotation status change can't skip the tier check by bypassing the UI.
-
- 2 Enable Supabase Row Level Security on every business table, scoped by role/org — not just client-side nav hiding.
-
- 3 Add requireRole() guards to all ~43 currently-unguarded render functions, prioritizing Finance, HR and Purchase screens.
-
- 4 Extend logActivity into a generic before/after change-log covering DOA approvals, deletions, role changes and price/rate overrides.
-

- 5 Replace the free-text Quotation/Invoice/Project customer fields with a real ID-bound select against `DB.customers`, and call `ensureCustomerExists` from all four entry points, not just Leads.

- 6 Add edit forms for Customer and Item masters, each writing an audit-log entry.

- 7 Fix the `customerId` population bug so the "Billed" aggregation is actually correct.

- 8 Link Material Requests to Purchase Orders via a `materialRequestId` field so procurement is demand-driven, not re-keyed.

- 9 Add a recalculation trigger, or at minimum a "stale cost" flag, when a material rate or costing default changes.

- 10 Build a real Warranty/AMC/Service module — the KPI framework already has placeholders (`service-sla`, `warranty-closure`) waiting for it.

- 11 Build a real Snag Management list — open/closed items per project, assigned-to, due date — instead of a single status label.

- 12 Link Receipts to specific Invoices for real AR aging instead of project-level guesswork.

- 13 Auto-generate the cutting list, material issue and machine schedule from the approved BOM when a production job is created.

- 14 Reserve/consume inventory at production job start, not only via the separate MR/Issue flow.

- 15 Consolidate the two purchase-entry code paths into one, backed by the acceptance workflow.

- 16 Add a multi-warehouse transfer function with location fields on warehouse items.

- 17 Delete the dead legacy password-hashing code now that Supabase Auth is the only live authentication path.

- 18 Raise the password minimum to 10+ characters with complexity rules, and add optional TOTP-based 2FA for CEO/Accounts/Finance at minimum.

19 Expand the 8 module-level roles into ~15–20 function-specific roles with real Create/Edit/Delete/Approve/Export flags, not just module visibility.

20 Add a lightweight Design/CAD attachment and Site Measurement capture screen — even just file-attachment plus structured dimension fields tied to a project ID — so drawings stop living entirely outside the system.

Priority Action Plan

IMMEDIATE

0–2 WEEKS

- Remove dead legacy password-hash code
- Fix the customerId/"Billed" bug
- Add kpiTargets and costingSettings to the Supabase sync list
- Guard the highest-risk unguarded screens (Payroll, Purchase Reports, CEO Dashboard, Receivables) with requireRole
- Add Customer and Item edit forms

SHORT-TERM

1–3 MONTHS

- Server-side DOA enforcement via a Postgres function or RLS policy
- Generic before/after change-log covering approvals, deletions and role changes
- Material Request → Purchase Order linkage
- Receipt → Invoice linkage for real AR aging
- Consolidate the two parallel purchase-entry code paths into one
- Expand the 8 module-level roles into function-specific roles with real Create/Edit/Delete/Approve/Export flags

LONG-TERM
3-12 MONTHS

- Warranty/AMC/Service ticketing module
- BOM-driven auto-generation of cutting list, material issue and machine schedule at job creation
- Inventory reservation tied to production job status, not only the separate MR/Issue flow
- Multi-warehouse transfer support with location fields on stock items
- Document management, attachments, barcode/QR for inventory
- Design/CAD attachment and structured Site Measurement capture, replacing free-text dimension fields
- A real Snag Management list with assignment, due dates and closure tracking
- An Asset register (machinery, vehicles, tools) with depreciation and maintenance history — separate from the production-scheduling DB.machines list
- 2FA and a stronger password policy for CEO/Accounts/Finance roles
- External API layer and multi-branch/multi-company readiness ahead of any scale-up past the current team size
- Wire Stage-Gate and QC failures into enforcement elsewhere (block downstream actions; auto-draft CAPA from failed QC)

09 · FINAL VERDICT

Certification against the ten questions that matter

1. Suitable for live operations now?

PARTIAL

Conditional yes — safe for the current 4-person team's happy-path daily use; not certifiable as secure or tamper-resistant enterprise-wide.

2. Can it support future growth?

NO

Not without redesign — single-tenant org_id, module-only RBAC and a single-file architecture will need real re-platforming well before 20–30 concurrent users.

3. Are all modules properly interconnected?

PARTIAL

The CRM→Quote→Project→Production→Dispatch core chain is genuinely wired; Procurement, AR reconciliation and Warranty are not.

4. Is duplicate data entry eliminated?

NO

No — confirmed duplicate/free-text entry for Customer identity across Quotation, Invoice and Project screens.

5. Is master data centralized?

PARTIAL

Mostly — Customer/Project/Employee/Vendor are single-sourced, but Item/Material is split across two disconnected arrays.

6. Are roles and permissions correctly implemented?

NO

No — 8 module-level roles, 4 real users, no CRUD/Approve granularity anywhere.

7. Is data visibility secure and role-based?

NO

No — enforcement covers 7 of ~50 screens; the page router itself has no guard.

8. Do edits propagate correctly across linked modules?

PARTIAL

Mixed — Employee changes propagate correctly; Customer/Item can't even be edited; cost-rate changes never propagate.

9. Are approval workflows robust and tamper-resistant?

NO

No — real tiered logic exists but is enforced client-side only, with no audit trail of who approved what.

10. Is it comparable to mature enterprise systems?

NO

Not yet — the domain automation in the core sales-to-dispatch chain is genuinely strong, but it sits on governance and access-control foundations well below SAP/Oracle/Dynamics/NetSuite baseline.

4.2/10

Overall ERP Maturity Score

58%

Go-Live Readiness

This is not a verdict on the effort invested — the sales-to-dispatch automation chain is more genuinely wired than most first-generation internal ERPs get to, and it already beats a typical out-of-box config on two rows of the **named benchmark** above. It's a verdict on whether the system is ready to be trusted as the company's single source of truth with real

approval authority and audit accountability behind it. It isn't yet, and the **20 ranked issues** — 14 of them Critical — are the gap between the two.

Appletree Interiors ERP Audit · code-verified against appletree_erp_v2_1.html · every citation is a file:line reference, re-verify before acting if the file has changed since 21 Jul 2026